

Nmap & Network Scanning

Commands · Scan Types · NSE Scripting · FTP & Host Discovery

Port Scanning

NSE Scripts

SMB / FTP

Host Discovery

Table of Contents

1. Nmap Notes — Commands, Scan Types & Key Concepts
2. Nmap + FTP + Network Scanning — Summary Notes
3. Nmap Host Discovery & Network Environment Effects

1. Nmap Notes — Commands, Scan Types & Key Concepts

Ports

- Ports identify the specific application or service running on a host.
- Total TCP/UDP port numbers: **65535** (1–65535).
- Well-known ports: **0–1023** (1024 ports total).
- Registered ports: **1024–49151**.
- Dynamic / Ephemeral ports: **49152–65535**.

Nmap Command-Line Options (Switches)

A **switch**, **option**, or **flag** all mean the same thing: a command-line argument that tells Nmap what to do.

Switch	Meaning
<code>-sS</code>	SYN Scan
<code>-sU</code>	UDP Scan
<code>-v</code>	Verbose output
<code>-p</code>	Specify ports

Common Scan Switches

SYN Scan — `-sS`

Also called: **Half-open Scan**, **Stealth Scan**

How it works:

1. Send SYN.
2. Receive SYN-ACK if port is open.
3. Send RST instead of ACK.
4. Connection is never fully established.

UDP Scan — `-sU`

Scans UDP ports.

Response	Result
UDP response	Open
ICMP Port Unreachable	Closed
No response	Open Filtered

Why "Open|Filtered"? If there's no response, Nmap can't tell whether the port is open (service stayed silent) or a firewall silently dropped the packet.

Verbose Mode — `-v`

- More detailed output while the scan is running.
- Does **NOT** change how Nmap scans.
- Does **NOT** make scans more accurate.

- `-vv` provides even more verbosity.

Saving Scan Results

Switch	Format	Notes
<code>-oN filename</code>	Normal	Human-readable output
<code>-oX filename</code>	XML	Used by automation tools
<code>-oG filename</code>	Grepable	Easily searched with <code>grep</code>
<code>-oA filename</code>	All formats	Creates .nmap, .xml, .gnmap in one scan

```
grep "22/open" scan.gnmap
```

Finds every host with SSH open.

Timing Templates

Flag	Name
<code>-T0</code>	Paranoid
<code>-T1</code>	Sneaky
<code>-T2</code>	Polite
<code>-T3</code>	Normal (default)
<code>-T4</code>	Aggressive
<code>-T5</code>	Insane (fastest)

Higher timing = faster scans, more network traffic, easier to detect, and may reduce reliability.

Port Selection

Command	Effect
<code>-p 1000-1500</code>	Scan ports 1000–1500
<code>-p 22,80,443</code>	Scan specific ports
<code>-p -</code>	Scan all TCP ports (1–65535)

Nmap scans **port numbers**, not "types" of ports.

NSE (Nmap Scripting Engine)

```
--script=vuln
--script vuln
```

Both syntaxes are valid. The `vuln` category runs scripts that check for known vulnerabilities and common security issues.

RFC (Request for Comments)

RFCs are official technical documents that define how Internet protocols should behave — think of an RFC as the official rulebook for a protocol.

RFC	Defines
RFC 9293	Current TCP specification
RFC 791	IPv4
RFC 768	UDP

NULL, FIN and Xmas Scans

Scan	Switch	Flags Set
NULL Scan	-sN	None
FIN Scan	-sF	FIN only
Xmas Scan	-sX	FIN, PSH, URG

Called "Xmas" because multiple TCP flags are "lit up" like a Christmas tree.

Why use these scans?

Historically used for firewall evasion — bypassing simple packet-filtering firewalls that only checked SYN packets. Modern firewalls usually detect these scans.

Windows and NULL/FIN/Xmas Scans

These scans depend on RFC-compliant TCP behavior:

System	Open Port	Closed Port
RFC-compliant	No response	RST
Windows	RST	RST

Result: Nmap cannot distinguish open from closed ports on Windows, so these scans are generally **ineffective** against it.

Meaning of Grepable Output

"Grepable" means the output is formatted so the Unix `grep` command can easily search it.

```
grep "80/open" scan.gnmap
```

Returns only hosts with port 80 open.

Quick Command Cheat Sheet

-sS	SYN Scan
-sU	UDP Scan
-sN	NULL Scan
-sF	FIN Scan
-sX	Xmas Scan
-v	Verbose output
-vv	More verbose
-p 1000-1500	Scan port range
-p 22,80,443	Scan selected ports
-p-	Scan all TCP ports
-oN file	Save normal output
-oX file	Save XML output
-oG file	Save grepable output
-oA file	Save all major output formats
-T0	Paranoid
-T1	Sneaky
-T2	Polite
-T3	Normal (default)
-T4	Aggressive
-T5	Insane
--script=vuln	Run all vulnerability NSE scripts
--script vuln	Same as above (also valid)

2. Nmap + FTP + Network Scanning — Summary Notes

1. Ping Sweep (Host Discovery)

```
nmap -sn 172.16.0.0/16
```

- `-sn` = disables port scan, only checks which hosts are up.
- `/16` comes from subnet mask `255.255.0.0`.

2. NSE Script Categories

Nmap scripts are grouped by risk/function:

Category	Description
<code>safe</code>	Low risk, safe for most environments
<code>default</code>	Commonly used scripts
<code>discovery</code>	Information gathering
<code>vuln</code>	Vulnerability checks
<code>intrusive</code>	Can disrupt services, not safe for production

Intrusive scripts are risky because they may crash services, overload systems, or cause instability.

3. NSE Script Arguments

Example: `ftp-anon.nse`

- Script-specific argument: `ftp-anon.maxlist`
- Purpose: limits number of listed files in FTP directory output.
- Optional because the script works without it and uses default behavior if not provided.

4. NSE Script Database (script.db)

Location:

```
/usr/share/nmap/scripts/script.db
```

Purpose: Index of all NSE scripts. Stores metadata like script names and categories (smb, vuln, safe, etc.).

Why it matters: Allows category search:

```
grep "smb" script.db
```

Without it, you can only search filenames in `/scripts/` — no category-based searching.

5. SMB Scripts

Example: `smb-os-discovery.nse`

Dependency shown:

```
dependencies = {"smb-brute"}
```

Meaning: `smb-os-discovery` can use results from `smb-brute`.

smb-brute: Attempts authentication using username/password combinations. Goal: find valid SMB credentials.

```
smb-brute → finds credentials → smb-os-discovery uses them
```

6. ICMP and Nmap Host Discovery

- ICMP (ping) is used to check if a host is alive.
- Often blocked by firewalls (especially Windows).

If ICMP is blocked:

```
-Pn
```

Meaning: skip host discovery, assume host is up.

7. OS Differences (ICMP behavior)

OS	ICMP Behavior
Windows	Often blocks ICMP (especially Public profile)
Linux	Usually allows ICMP by default, but can be blocked via firewall/kernel settings

Key point: Not an OS-based rule — depends on firewall configuration.

8. Xmas Scan Results

```
nmap -sX -p1-999 <target>
```

Output example:

```
Not shown: 999 open|filtered
```

Meaning: all scanned ports behaved the same, so Nmap compresses output instead of listing each port.

Final answer example: `999`

9. Nmap Packet Obfuscation

```
--data-length <num>
```

- Appends random bytes to packets.
- Used to evade simple IDS signatures and change packet fingerprinting.

10. FTP Anonymous Login (ftp-anon script)

```
nmap -p 21 --script ftp-anon <target>
```

Result:

Anonymous FTP login allowed (FTP code 230)

Meaning: authentication succeeded (server accepted login). But:

Can't get directory listing: TIMEOUT

Means: data channel failed (no file listing).

Key FTP concept

FTP has 2 parts:

1. Control channel → login (worked ✓)
2. Data channel → file transfer/listing (failed ✗)

11. Important Concept Clarifications

Did we "log in" with ftp-anon?

- ✓ **Yes** — authentication succeeded automatically via Nmap.
- ✗ **No** interactive session was performed.

Can we access files?

- Not necessarily — login success ≠ full access.

Core Takeaways

- Nmap often performs actions automatically (like FTP login checks).
- "open|filtered" means Nmap cannot distinguish state due to no response.
- `-Pn` is used when ping/ICMP discovery fails.
- NSE scripts can depend on other scripts.
- `script.db` enables category-based script searching.
- FTP login success and file access are separate steps.

3. Nmap Host Discovery & Network Environment Effects

1. Nmap does NOT rely on a single method for host discovery

It uses multiple probes in sequence or combination:

- ICMP Echo Request (ping)
- ICMP Timestamp request
- TCP SYN probes (common ports like 80/443)
- TCP ACK probes
- ARP requests (only in local LAN)

Nmap tries several methods until it gets a response.

2. Why `-Pn` is needed sometimes

`-Pn` means: skip host discovery and assume host is up.

Used when:

- ICMP is blocked
- TCP probes are filtered
- No responses are received at all

Without `-Pn`, Nmap may output:

```
Host seems down
```

3. Network environment heavily affects Nmap results

A. Same LAN (local VM lab)

- ARP works ✓ (most reliable)
- Devices respond normally ✓
- Minimal filtering

Result: Host discovery works easily; accurate port states (open/closed).

B. Remote/VPN environments (TryHackMe)

- No ARP ✗
- ICMP often blocked ✗
- TCP probes may be filtered ✗

Result: Host may appear "down"; `-Pn` often required; more `open|filtered` results.

C. Firewall-heavy environments

Packets silently dropped.

Result: Ports show as `filtered` or `open|filtered`; low certainty in scan results.

D. Open/weakly filtered environments

Services respond normally.

Result: Clear and accurate scan output.

4. Key insight

Nmap output depends on what the network allows you to observe – not just what you scan.

5. Important correction

- It is **NOT** "mainly ICMP".
- It is a combination of ICMP + TCP + ARP (LAN only).
- Whichever probe gets a response determines host status.

6. Core takeaway

- Same scan ≠ same result everywhere.
- Environment (LAN, VPN, firewall) changes everything.
- `-Pn` is a workaround for missing discovery responses.